

CS-590 Database Design and Development

8-1 Short Paper: Data Security and Privacy Regulations

Malgorzata Debska

Southern New Hampshire University

Zach Probst

March 23, 2026

HIPAA Compliance, Database Security, and the Change Healthcare Cyberattack

In an increasingly digital healthcare environment, the protection of sensitive patient information has become a critical priority. Healthcare organizations rely heavily on databases to store and manage protected health information (PHI), making them prime targets for cyberattacks. Regulatory frameworks such as the Health Insurance Portability and Accountability Act (HIPAA) provide strict standards to safeguard this data. However, compliance requires not only awareness of legal requirements but also the proper implementation of technical controls within database systems. This paper examines HIPAA's requirements for data storage, access, and transmission, analyzes the role of database design in achieving compliance, and evaluates the 2024 Change Healthcare cyberattack as a real-world example of security failure. Also, it proposes practical security strategies that database professionals can implement to prevent similar incidents in the future.

HIPAA Requirements for Data Storage, Access, and Transmission

HIPAA, enacted in 1996, includes the Privacy Rule and Security Rule, which together define how PHI must be protected. These regulations impose specific requirements across three critical domains: data storage, access, and transmission.

Data Storage Requirements

HIPAA mandates that PHI must be securely stored to prevent unauthorized access, alteration, or loss. Organizations must implement both technical and physical safeguards. From a database perspective, this includes encrypting stored data, keeping secure backups, and ensuring data integrity. Integrity controls are particularly important, as they ensure that patient data is not improperly altered or destroyed (U.S. Department of Health & Human Services). Adding to that, organizations must support contingency plans, including data recovery procedures, to ensure that PHI is still available even in case of system failure or cyberattack.

Access Control Requirements

HIPAA emphasizes strict access control through the principle of minimum necessary use, meaning that individuals should only access the information needed to perform their job functions. Database systems must enforce role-based access control (RBAC), ensuring that permissions are aligned with user responsibilities. Furthermore, HIPAA requires unique user identification, secure authentication mechanisms, and audit controls that log user activity. These logs are essential for detecting unauthorized access and supporting forensic investigations if a breach.

Transmission Security Requirements

When PHI is transmitted electronically, it must be protected against interception or unauthorized disclosure. HIPAA requires encryption or equivalent safeguards during transmission, particularly over public or unsecured networks. Secure communication protocols such as Transport Layer

Security (TLS) are commonly used to ensure that data stays confidential and intact while being transmitted between applications, databases, and users.

Compliance Needs in Database Design

Achieving HIPAA compliance requires integrating security directly into database architecture.

This involves implementing encryption, authentication, and authorization mechanisms that align with regulatory standards.

Encryption

Encryption is a fundamental requirement for protecting PHI. Data must be encrypted both at rest and in transit. Advanced Encryption Standard (AES-256) is widely used for securing stored data, while TLS ensures secure communication between systems. Encryption minimizes the impact of data breaches by giving stolen data unreadable without the proper decryption keys. According to CISA (2024), encryption is one of the most effective controls for reducing the severity of cyber incidents.

Authentication

Authentication ensures that only authorized users can access the database. HIPAA-compliant systems should implement multi-factor authentication (MFA), which requires users to verify their identity through multiple credentials (e.g., password and a one-time code). MFA significantly reduces the risk of unauthorized access due to compromised passwords, which is a common attack vector in healthcare breaches.

Authorization

Authorization decides what actions authenticated users can perform. Role-based access control (RBAC) ensures that users can only access data relevant to their role. For example, administrative staff may access billing information but not clinical records. Fine-grained authorization mechanisms further restrict access at the field or record level, providing an added layer of protection for extremely sensitive data.

Cyber Incident: Change Healthcare Data Breach (2024)

In 2024, Change Healthcare, a subsidiary of UnitedHealth Group, experienced one of the most significant healthcare cyberattacks in recent history. The attack was attributed to a ransomware group that gained unauthorized access to the company's systems and exfiltrated sensitive data. The breach disrupted critical healthcare operations across the United States, including prescription processing and insurance claims. Millions of individuals were affected, and the incident exposed vulnerabilities in both infrastructure and database security. This breach is particularly relevant to HIPAA compliance because it involved the exposure of PHI and highlighted failures in implementing required safeguards.

Failure to Comply with HIPAA

The Change Healthcare cyberattack proved multiple failures to meet HIPAA's security requirements.

- **Weak Authentication and Access Controls**

One of the primary issues named in the breach was the lack of robust authentication measures. Reports show attackers gained access through compromised credentials without meeting multi-factor authentication. This stands for a direct violation of HIPAA's access control requirements.

- **Insufficient Monitoring and Risk Management**

HIPAA requires continuous monitoring of systems to detect and respond to security incidents. The scale and duration of the attack suggest that intrusion detection and response mechanisms were either inadequate or not effectively implemented.

- **Inadequate Data Protection Measures**

The large volume of compromised data says that encryption and segmentation controls were insufficient. Properly implemented encryption could have limited the usability of stolen data, while network segmentation could have prevented attackers from accessing multiple systems.

Recommended Security Techniques and Protocols

To enhance database security and ensure HIPAA compliance, organizations should implement the following measures:

Multi-Factor Authentication (MFA)

Require MFA for all users, especially those with administrative privileges. This significantly reduces the likelihood of unauthorized access.

End-to-End Encryption

Encrypt data both at rest and in transit using strong encryption standards. Secure all database connections and APIs using TLS.

Role-Based Access Control (RBAC)

Implement strict access controls based on user roles. Regularly review and update permissions to ensure compliance with the principle of least privilege.

Network Segmentation

Divide systems into separate network zones to limit the spread of attacks. Sensitive databases should be isolated from general network access.

Continuous Monitoring and Logging

Deploy real-time monitoring tools and support detailed audit logs. This enables early detection of suspicious activity and supports incident response.

Secure Database Configuration

Ensure databases are not publicly accessible, disable default accounts, enforce strong password policies, and apply regular security updates.

Justification of Recommendations

The recommended security measures directly address the vulnerabilities found in the Change Healthcare breach.

- MFA would have prevented unauthorized access even if credentials were compromised.
- Encryption ensures that stolen data is still unusable without decryption keys.
- RBAC and segmentation limit the scope of access, reducing the potential impact of a breach.
- Monitoring and logging enable faster detection and response, minimizing damage.

By implementing these controls, organizations can significantly reduce the risk of data breaches and ensure compliance with HIPAA regulations. These measures not only protect sensitive data but also strengthen overall system resilience.

To conclude, HIPAA provides a framework for protecting sensitive healthcare data, but compliance depends on effective implementation within database systems. The Change Healthcare cyberattack serves as a powerful example of how failures in authentication, access control, and monitoring can lead to severe consequences. Database professionals must prioritize security in system design by integrating encryption, authentication, and authorization mechanisms. By adopting proactive security strategies, healthcare organizations can better protect patient data, support regulatory compliance, and prevent future cyber incidents.

References

Cybersecurity & Infrastructure Security Agency (CISA). (2024). *Ransomware guidance and healthcare sector alerts*.

U.S. Department of Health & Human Services. (n.d.). *Health Insurance Portability and Accountability Act (HIPAA)*. <https://www.hhs.gov/hipaa/index.html>

American Hospital Association. (2024). *Change Healthcare Cyberattack impact report*.

.

